

VULNERABILITY MANAGEMENT POLICY

Based on SANS/CRF Cybersecurity Policy Template, February 2026
Server Security Category (Compute)

Version	Effective Date	Document Owner	Status
1.0	March 28, 2026	Noe Valencia	Active

Do not distribute externally.

1. Purpose

This Vulnerability Management Policy establishes a systematic and proactive framework for identifying, assessing, prioritizing, remediating, and tracking vulnerabilities across all systems, servers, applications, and network devices within our organization's IT infrastructure. Vulnerabilities in server and endpoint environments represent one of the most consistently exploited attack vectors in the current threat landscape.

According to FIRST's 2026 vulnerability forecast, approximately 59,000 CVEs are projected to be published this year, representing an unprecedented volume that makes purely reactive patch management operationally impossible. The Cyber Strategy Institute's 2026 vulnerability report found that 53% of organizations have at least one open internet-facing vulnerability, with a median time to close half of exposed vulnerabilities of 361 days, while exploitation often occurs within 0 to 5 days of public disclosure. This policy implements the controls required to close that gap through systematic scanning, risk-based prioritization, defined remediation SLAs, and multi-audience reporting that ensures vulnerabilities receive attention at every level of the organization.

2. Scope

This policy applies to all employees, contractors, and stakeholders involved in managing, operating, or supporting the organization's IT infrastructure. It encompasses all systems subject to vulnerability, including:

- Physical and virtual servers, including on-premises, co-located, and cloud-hosted instances
- Workstations, laptops, and endpoint devices
- Network devices including routers, switches, and firewalls
- Web applications, APIs, and application servers
- Databases and storage systems
- IoT and operational technology devices connected to organizational networks
- Third-party software and open-source components deployed in the environment

Compliance with this policy is mandatory for all in-scope individuals. Deviations require written approval through the exception process defined in Section 12.

3. Principle Statement

Vulnerability management is a continuous operational discipline, not a periodic compliance exercise. Given that attackers now weaponize new CVEs within hours of public disclosure, the organization must maintain persistent visibility into its vulnerability posture, prioritize remediation based on actual exploitability rather than CVSS score alone, and track progress with the same rigor applied to other critical operational metrics.

This policy is governed by the principle of risk-based prioritization: not all vulnerabilities are equal, and remediation resources must be directed at the vulnerabilities that pose the greatest actual risk to the organization. Vulnerabilities appearing in the CISA Known Exploited Vulnerabilities (KEV) catalog, those with public exploit code available, and those on internet-facing systems are prioritized above theoretical risks with no known exploitation in the wild. The CIA Triad, Confidentiality, Integrity, and Availability, governs all vulnerability management decisions.

4. Senior Management Commitment

Senior management is fully committed to the implementation and enforcement of this Vulnerability Management Policy. We recognize that unpatched server and system vulnerabilities are among the most preventable and consistently exploited entry points for ransomware, data breaches, and unauthorized access. We commit to providing the scanning tools, remediation resources, and organizational authority required to manage vulnerabilities effectively.

This policy will be reviewed annually and updated to reflect material changes in the threat landscape, applicable standards, or organizational infrastructure.

Signed: _____ Date: _____
Chief Information Security Officer / Senior IT Leadership

5. How Similar Organizations Handle Vulnerability Management

Research into peer organizations and industry frameworks reveals consistent and evolving approaches to vulnerability management that inform the controls in this policy.

5.1 Federal Government, CISA Binding Operational Directive 22-01 and KEV Catalog

The U.S. Cybersecurity and Infrastructure Security Agency (CISA) maintains the Known Exploited Vulnerabilities (KEV) catalog, which lists CVEs confirmed to be actively exploited in the wild. Under Binding Operational Directive 22-01, federal civilian agencies are required to remediate all KEV catalog vulnerabilities within defined timeframes: 2 weeks for critical KEV items and 6 months for all others. The KEV catalog has become the gold standard for vulnerability prioritization beyond the federal sector, with organizations across financial services, healthcare, and technology adopting it as their primary remediation prioritization signal. CISA added CVE-2025-53521, a critical RCE in F5 BIG-IP APM with a CVSS score of 9.8, to the KEV catalog on March 28, 2026, giving federal agencies until March 30 to assess exposure, illustrating the velocity at which organizations must operate.

5.2 Financial Services Sector, Risk-Based Vulnerability Management

Financial services organizations subject to PCI DSS v4.0, SOX, and DORA have moved from calendar-based patching cycles to continuous, risk-based vulnerability management programs. Key practices include weekly authenticated scans of all in-scope systems, a 30-day remediation SLA for critical vulnerabilities and 90 days for high, mandatory penetration testing at minimum annually, integration of vulnerability scan data with SIEM platforms for correlation, and executive-level vulnerability reporting dashboards showing open vulnerability counts, SLA compliance rates, and trend lines. IBM X-Force 2025 research found that CIS, PCI DSS, and ANSSI compliance frameworks most commonly aligned with the vulnerabilities organizations prioritize, confirming that regulatory expectations continue to drive vulnerability management maturity.

5.3 Enterprise Technology Sector, Continuous and Automated Vulnerability Management

Large technology organizations such as Microsoft, Google, and AWS have adopted continuous vulnerability management programs built around automated agent-based scanning, integration of vulnerability data into CI/CD pipelines, mandatory remediation SLAs tied to CVSS severity, and virtual patching through WAF and IPS rules for vulnerabilities that cannot be immediately patched.

Microsoft's February 2026 security baseline update (v2602) for Windows Server 2025 introduced updated configuration standards for enterprise server environments, demonstrating how major vendors are continuously evolving their hardening guidance. Organizations that align their vulnerability management programs to vendor baselines alongside CVE scanning achieve materially better security outcomes than those relying on CVE-only scanning.

6. Current Industry Trends (2026)

This policy reflects the most current thinking on vulnerability management as of 2026.

6.1 Unprecedented CVE Volume Requires Prioritization Over Completeness

FIRST's 2026 vulnerability forecast projects approximately 59,000 CVEs published this year, with an upper bound of 118,000. In 2025, 48,448 CVEs were published. At this volume, organizations cannot patch everything and must prioritize ruthlessly. The Cyber Strategy Institute's 2026 report found that many sectors require 9 to 19 months to close half of exposed vulnerabilities, while exploitation often lands within 0 to 5 days of disclosure. This policy's VUL-06 (prioritization) control is the most operationally critical safeguard given this reality. Risk-based prioritization using KEV catalog status, EPSS scores, and internet-facing exposure must replace CVSS-score-only approaches.

6.2 Exploitation Velocity Is Accelerating

The NSHC ThreatRecon 2026 vulnerability exploitation landscape report found that the pattern of simultaneous global scanning and exploitation occurring immediately after vulnerability disclosure has become common. Proof-of-concept exploit code is now being generated and deployed within hours of CVE publication in some cases. This acceleration means that the traditional 30-day patch window for critical vulnerabilities is increasingly inadequate for internet-facing systems. Virtual patching via WAF and IPS rules, combined with network segmentation, is becoming a necessary interim control while formal patching proceeds through change management workflows.

6.3 Authenticated and Agent-Based Scanning Is the Standard

Unauthenticated network scans consistently miss 30 to 60% of vulnerabilities present on a system because they cannot assess the internal software inventory or configuration state. The industry standard in 2026 requires both agent-based scanning for detailed endpoint visibility and authenticated network scans for coverage of agentless or network-only devices. Tools such as Tenable Nessus, Qualys, Rapid7 InsightVM, and Microsoft Defender Vulnerability Management all support authenticated and agent-based scanning modes. VUL-02 mandates this approach to ensure scan completeness.

6.4 CVE and CCE Coverage Together

Modern vulnerability management programs scan for both software vulnerabilities (CVEs, Common Vulnerabilities and Exposures) and configuration weaknesses (CCEs, Common Configuration Enumerations). CVE scanning identifies unpatched software. CCE scanning identifies misconfigured systems that may be exploitable even without a known CVE, such as unnecessarily open ports, default credentials left in place, and weak cipher suite configurations. Microsoft's Windows Server 2025 security baseline (v2602) released in February 2026 explicitly addresses configuration-level controls including sudo behavior, NTLM auditing, and legacy protocol disablement. VUL-03 and VUL-04 together ensure both vectors are covered.

6.5 Multi-Audience Reporting Is a Governance Requirement

Effective vulnerability management requires different information delivered to different audiences. Technical staff need detailed CVE lists with remediation guidance. Business unit staff need to understand which systems affecting their operations carry open vulnerabilities. Leadership needs trend metrics, SLA compliance rates, and risk posture summaries that translate vulnerability data into business risk language. VUL-10, VUL-11, and VUL-12 implement this three-tier reporting structure, reflecting the governance expectation that vulnerability risk is visible at every organizational level, not just in the security team's queue.

6.6 Penetration Testing as Validation

Vulnerability scanning identifies known vulnerabilities based on CVE and CCE databases. Penetration testing goes further by attempting to chain and exploit vulnerabilities to determine actual exploitability and impact in the specific environment. Industry best practice in 2026 requires both: continuous scanning for known vulnerabilities and periodic penetration testing to validate that the vulnerability management program is actually reducing risk, not just reducing scan counts. CISA's server security guidance and PCI DSS v4.0 both require annual penetration testing at minimum.

7. Roles and Responsibilities

Role	Primary Responsibilities
IT Security Manager	Policy owner; oversees VM system operation; sets remediation SLAs; approves exceptions; escalates unresolved critical vulnerabilities to leadership
Systems Administrator	Deploys and maintains scanning agents; remediates identified vulnerabilities per SLA; implements configuration fixes for CCE findings; coordinates with change management
Security Analyst	Reviews scan results; validates prioritization; investigates anomalies; produces technical and business reporting; tracks open vulnerability aging
IT Manager	Receives business unit vulnerability reports; ensures remediation resources are allocated; approves emergency patching outside normal change windows
Business Leadership	Receives executive vulnerability posture reports; provides organizational authority for resource allocation to address critical unresolved vulnerabilities
All Staff	Must not interfere with vulnerability scanning agents; must report suspected system compromises immediately to IT Security Manager

8. Policy Safeguards

The following safeguards are derived from the SANS/CRF Vulnerability Management Policy template (February 2026) and expanded with technical rationale grounded in CIS Controls v8, NIST SP 800-53, CISA guidance, and current industry practice. All safeguards are mandatory unless a formal exception has been granted per Section 12.

8.1 Vulnerability Management System and Scanning

Control	Safeguard	Technical Rationale and Industry Alignment
VUL-01	Maintain a centralized Vulnerability Management (VM) system to detect, track, and manage weaknesses across all of the organization's information systems. The VM system must cover all in-scope assets defined in Section 2.	CIS Control 7 (Continuous Vulnerability Management) requires a centralized VM system as the foundation of all other vulnerability controls. Without a unified system, scan coverage gaps, duplicate findings, and inconsistent remediation tracking are inevitable.
VUL-02	Ensure the VM system uses both agent-based scanning and authenticated network scans to detect weaknesses. Unauthenticated scans alone are not sufficient to meet this requirement.	Unauthenticated scans miss 30 to 60% of actual vulnerabilities. Agent-based scanning provides deep endpoint visibility including installed software inventory and local configuration state. Authenticated scans cover network devices and agentless systems. Together they provide comprehensive coverage aligned with NIST SP 800-40 and CIS Control 7.
VUL-03	Ensure the VM system scans for CVE-based software vulnerabilities, including all software packages, libraries, operating system components, and applications installed on in-scope systems.	CVEs represent known exploitable software vulnerabilities. FIRST projects 59,000 CVEs in 2026. The CISA KEV catalog contains CVEs confirmed exploited in the wild and must be cross-referenced. Scanning for CVEs is the baseline requirement of PCI DSS v4.0, NIST SI-2, and CIS Control 7.2.
VUL-04	Ensure the VM system scans for CCE-based configuration weaknesses, including insecure default settings, unnecessary services, weak cipher configurations, and policy deviations from approved security baselines.	Misconfiguration is the leading cause of cloud breaches and a top cause of on-premises server compromise. CCE scanning identifies configuration drift from approved baselines such as CIS Benchmarks and Microsoft's Windows Server 2025 security baseline (v2602). Configuration weaknesses can be exploitable without any associated CVE.
VUL-05	Ensure the VM system scans for open, dangerous, or unnecessary network ports and services on all in-scope systems, and alerts when unauthorized services are detected.	Unnecessary open ports and services expand the attack surface. Each open service is a potential exploitation vector. CIS Control 4 (Secure Configuration) requires that only authorized services are running. Port scanning combined with service fingerprinting identifies deviations from approved baselines.

8.2 Prioritization and Remediation

Control	Safeguard	Technical Rationale and Industry Alignment
VUL-06	Ensure the VM system prioritizes discovered vulnerabilities using a risk-based framework that considers CVSS score, CISA KEV catalog status, EPSS (Exploit Prediction Scoring System) score, internet-facing exposure, and asset	Risk-based prioritization is the most operationally critical control given the volume of CVEs published annually. CVSS alone is insufficient; KEV catalog status and EPSS scores better reflect actual exploitation likelihood. CISA BOD 22-01 mandates KEV

Control	Safeguard	Technical Rationale and Industry Alignment
	criticality. The following remediation SLAs apply: Critical (CVSS 9.0 to 10.0 or KEV listed): 15 days for internet-facing systems, 30 days for internal systems. High (CVSS 7.0 to 8.9): 30 days. Medium (CVSS 4.0 to 6.9): 90 days. Low (CVSS below 4.0): 180 days or next scheduled maintenance.	remediation within 2 weeks for federal agencies. The SLAs in this policy align with PCI DSS v4.0 and NIST SP 800-40 guidance.
VUL-07	Ensure the VM system compares consecutive scan results to track remediation progress over time, identifying newly discovered vulnerabilities, successfully remediated items, and vulnerabilities that have aged beyond their remediation SLA.	Trend comparison transforms scanning from a point-in-time activity into a continuous improvement program. Comparing scan results identifies regression (new vulnerabilities appearing on previously clean systems), stalled remediation, and the overall trajectory of the vulnerability posture. This aligns with CIS Control 7.7 (remediation tracking).
VUL-08	Ensure the VM system maintains a continuously updated register of all open vulnerabilities, including their severity, affected system, assigned owner, discovery date, SLA deadline, and current remediation status.	An open vulnerability register provides the operational visibility required to manage remediation at scale. Without it, vulnerabilities fall through the cracks, SLA deadlines are missed, and there is no auditable evidence of the organization's vulnerability posture for compliance or incident response purposes.

8.3 Exception Tracking and Reporting

Control	Safeguard	Technical Rationale and Industry Alignment
VUL-09	Ensure the VM system tracks all approved vulnerability exceptions, including the CVE or CCE identifier, affected system, business justification, compensating controls in place, approving authority, and exception expiration date. Exceptions must be reviewed at minimum quarterly.	Not all vulnerabilities can be immediately patched. Legacy systems, vendor support constraints, and operational dependencies sometimes require documented risk acceptance. Tracking exceptions formally prevents them from becoming invisible permanent deferrals and ensures they are reviewed and renewed with full awareness of the associated risk. This aligns with NIST RA-7 (Risk Response) and PCI DSS requirement 6.
VUL-10	Ensure the VM system generates regular vulnerability reports for technical staff including Security Analysts and Systems Administrators. Reports must include newly discovered vulnerabilities, SLA status for open items, scan coverage metrics, and remediation trend data. Reports must be generated at minimum weekly.	Technical staff are the primary remediation operators. Weekly technical reporting ensures they have current, actionable vulnerability data without delay. The format must include enough technical detail to directly drive remediation actions, including CVE identifiers, affected software versions, and remediation guidance.

Control	Safeguard	Technical Rationale and Industry Alignment
VUL-11	Ensure the VM system generates regular vulnerability reports for business unit staff, summarizing open vulnerabilities affecting systems supporting their business functions, expressed in business impact terms rather than technical detail. Reports must be generated at minimum monthly.	Business unit staff are not security specialists but are accountable for the systems supporting their operations. Monthly business-oriented reporting creates shared accountability for remediation and ensures that prolonged open vulnerabilities in business-critical systems receive appropriate organizational attention beyond the IT security team.
VUL-12	Ensure the VM system generates regular executive vulnerability posture reports for business leadership. Reports must include overall vulnerability trend metrics, SLA compliance rates, critical open vulnerability counts, and risk posture summary expressed in business risk terms. Reports must be generated at minimum monthly.	Leadership needs vulnerability data translated into business risk language to make informed resource allocation decisions. IBM X-Force and Gartner research both identify lack of executive visibility into vulnerability posture as a key factor in organizations' inability to secure adequate remediation resources. Monthly executive reporting closes this governance gap.

9. Remediation SLA Summary

The following table summarizes the remediation service level agreements defined in VUL-06 and applies to all in-scope systems:

Severity	CVSS Range	Internet-Facing SLA	Internal System SLA
Critical (or KEV listed)	9.0 to 10.0	15 days	30 days
High	7.0 to 8.9	30 days	30 days
Medium	4.0 to 6.9	90 days	90 days
Low	Below 4.0	180 days	Next maintenance window

Vulnerabilities listed in the CISA Known Exploited Vulnerabilities (KEV) catalog are treated as Critical regardless of their CVSS score, due to confirmed active exploitation. The IT Security Manager may escalate SLA timeframes for any vulnerability based on active threat intelligence.

10. Legal and Regulatory Obligations

Framework / Standard	Relevance to This Policy
NIST SP 800-40 Rev 4, Patch Management	Defines patch management program requirements including scan frequency, remediation SLAs, and exception handling

Framework / Standard	Relevance to This Policy
NIST SP 800-53 Rev 5	SI-2 (Flaw Remediation), RA-5 (Vulnerability Scanning), SI-6 (Security Function Verification)
NIST Cybersecurity Framework (CSF) 2.0	Identify (ID.RA) and Protect (PR.IP) functions: vulnerability assessment and remediation
CIS Controls v8	Control 7 (Continuous Vulnerability Management): scanning, prioritization, remediation, and reporting requirements
CISA Binding Operational Directive 22-01	KEV catalog remediation mandates adopted as industry best practice for prioritization
PCI DSS v4.0	Requirements 6.2, 6.3, 11.3: vulnerability scanning, penetration testing, and remediation SLAs for cardholder data environments
ISO/IEC 27001:2022	Annex A.8.8 (Management of technical vulnerabilities): scanning, assessment, and remediation requirements
DORA (Digital Operational Resilience Act)	ICT risk management requirements including vulnerability identification and remediation for financial sector organizations

11. Training and Awareness

All personnel with responsibilities under this policy must receive training appropriate to their role:

- Systems Administrators: Annual training on VM system operation, authenticated scan configuration, CVE and CCE remediation procedures, and emergency patching protocols outside normal change windows.
- Security Analysts: Ongoing training on vulnerability prioritization frameworks including KEV catalog and EPSS scoring, vulnerability report generation, and trend analysis.
- Business Unit Staff and Leadership: Annual training on interpreting vulnerability posture reports and their responsibilities in supporting timely remediation of systems within their business functions.

Training completion records are maintained by the IT Security Team and retained for a minimum of three years.

12. Compliance Measurement

Compliance with this policy is assessed through the following scheduled activities:

Activity	Controls Assessed	Frequency
Full authenticated vulnerability scan	VUL-01 through VUL-05	Weekly
Scan coverage verification	VUL-01, VUL-02	Monthly
Remediation SLA compliance review	VUL-06, VUL-07, VUL-08	Weekly

Activity	Controls Assessed	Frequency
Open vulnerability register review	VUL-08	Weekly
Exception register review	VUL-09	Quarterly
Technical staff report generation	VUL-10	Weekly
Business unit report generation	VUL-11	Monthly
Executive posture report generation	VUL-12	Monthly
Annual penetration test	All VUL controls	Annual

Critical and KEV-listed vulnerabilities on internet-facing systems that exceed their 15-day SLA are automatically escalated to senior IT leadership. Results are documented and retained for three years minimum.

13. Exception Management

Operational or technical constraints may occasionally prevent timely remediation of a specific vulnerability. All exceptions must follow this process:

- The requesting System Administrator or IT Manager submits a written exception request to the IT Security Manager documenting the CVE or CCE affected, the system involved, the technical or business justification for deferral, the compensating controls in place, and the requested duration (maximum 90 days).
- Critical and KEV-listed vulnerability exceptions require IT Security Manager and senior IT leadership approval. All other severity exceptions require IT Security Manager approval only.
- All approved exceptions are logged in VUL-09's exception register with full documentation.
- The exception register is reviewed quarterly. Expired exceptions not formally renewed are treated as open policy violations and escalated immediately.
- Compensating controls such as virtual patching via WAF or IPS rules, network isolation, or enhanced monitoring must be implemented and documented before any exception takes effect.

14. Policy Sanctions

Non-compliance with this policy will result in disciplinary action consistent with the organization's human resources policies. Sanctions are applied consistently and proportionally:

Severity	Consequence
Minor / Unintentional	Mandatory refresher training; written notice; increased monitoring for 90 days

Severity	Consequence
Moderate / Negligent	Formal written warning; review of remediation responsibilities with IT Security Manager; mandatory remediation of all SLA-overdue items within 30 days
Severe / Willful Violation	Immediate review of system access; HR investigation; potential removal of administrative access; potential termination of employment or contract
Criminal / Illegal Activity	All above consequences plus referral to law enforcement; legal action under applicable federal and state statutes

15. Continual Improvement

This policy is reviewed at minimum annually. Earlier review is triggered by any of the following:

- A security incident involving an unpatched vulnerability or configuration weakness
- Addition of a new system category or major infrastructure change that affects scan coverage
- Material updates to CISA KEV catalog priorities, NIST guidance, or CIS Controls
- Changes to applicable regulatory requirements
- Findings from penetration testing or third-party security assessments identifying gaps in this policy's controls

The IT Security Manager coordinates annual reviews, incorporates lessons learned from incidents and penetration test findings, benchmarks SLA timeframes against peer organizations and regulatory requirements, and ensures the policy reflects the current exploitation velocity landscape. All revisions are documented and communicated to all in-scope personnel within 10 business days of approval.

16. Sources and References

Source	URL / Reference
SANS/CRF Vulnerability Management Policy Template (Feb 2026)	https://www.sans.org/information-security-policy/vulnerability-management-policy
CIS Controls v8, Control 7: Continuous Vulnerability Management	https://www.cisecurity.org/controls/v8
CIS Benchmarks (2026)	https://www.cisecurity.org/cis-benchmarks
NIST SP 800-40 Rev 4, Patch Management	https://csrc.nist.gov/publications/detail/sp/800-40/rev-4/final
NIST SP 800-53 Rev 5	https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final
NIST Cybersecurity Framework (CSF) 2.0	https://www.nist.gov/cyberframework
CISA Known Exploited Vulnerabilities (KEV) Catalog	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
CISA Binding Operational Directive 22-01	https://www.cisa.gov/binding-operational-directive-22-01
PCI DSS v4.0	https://www.pcisecuritystandards.org/document_library/

Source	URL / Reference
ISO/IEC 27001:2022	https://www.iso.org/standard/82875.html
FIRST: Vulnerability Forecast 2026	https://www.first.org/blog/20260211-vulnerability-forecast-2026
Cyber Strategy Institute: 2026 Vulnerability Report	https://cyberstrategyinstitute.com/2026-vulnerability-report/
NSHC ThreatRecon: Vulnerability Exploitation Landscape 2025 to 2026	https://medium.com/@nshcthreatrecon/vulnerability-exploitation-landscape-2025-trends-and-2026-outlook-6e375cfc8861
IBM X-Force: Cloud Attacks Evolving 2025 Trends for 2026	https://www.ibm.com/think/x-force/cloud-attacks-evolving-what-2025-trends-mean-defenders-2026
Microsoft Windows Server 2025 Security Baseline v2602	https://petri.com/windows-server-2025-security-baseline-update/
Help Net Security: CVE-2025-53521 F5 BIG-IP APM Active Exploitation	https://www.helpnetsecurity.com/2026/03/28/big-ip-apm-vulnerability-cve-2025-53521-exploited/
Patrowl: Vulnerability Forecast 2026	https://patrowl.io/en/actualites/vulnerability-forecast-2026-what-organizations-can-expect
CyberCrest: Vulnerability Management Best Practices 2026	https://www.cybercrestcompliance.com/blog/vulnerability-management-best-practices